

AegisCare HMS — DHA Compliance Assessment

System	AegisCare HMS (LabTrack v5.5 codebase)
Repository	fmurage6331-dev/confit-core
Branch assessed	arena/01a037b8-confit-core
Date	2026-08-25
Document type	DHA certification readiness / compliance gap assessment
Related docs	docs/certification/DOC-1...8, docs/certification/DOC-7-self-attestation-gap-analysis.md, docs/dha-compliance-task-*.md

Scope. This assessment reviews the current AegisCare HMS implementation against Kenya's Digital Health Act, 2023; the Digital Health (Data Exchange Component) Regulations, 2025; the Digital Health (Health Information Management Procedures) Regulations, 2025; the Kenya eClaims FHIR Implementation Guide; the Kenya Health Information Systems Interoperability Framework (KHISIF); the Kenya Data Protection Act, 2019; the Social Health Insurance Act, 2023; and the DHA AfyaLink HIE / SHA claims requirements.

This is NOT a formal DHA certificate. It is a developer gap assessment intended to be used as the basis for a DHA Certification self-attestation (Form HMIS 4 pathway) and for remediation planning.

Executive Summary

AegisCare HMS has a **substantial, well-structured local clinical and SHA claims layer**: FHIR R4 Encounter/Patient/Condition builders, ICD-11 diagnosis sync, SHA claims tables and auto-generation, FHIR Claim generation, dha_outbound_queue dispatch, SHA claim status history, state-machine UI, PHF marker, claims aging view, KMHFL auto-sync, DSAR export, audit triggers, and RLS-based role protection.

However, the system is **not yet DHA-certified or live SHA-submitting**. The major blockers are:

- Missing external credentials** — SHA/DHA API keys, JWT/OAuth credentials, AfyaLink test and production onboarding.
- Fragile SHA Claim FHIR conformance** — build_fhir_claim() now emits correct sha_claim_items columns, but the output has **not** been validated against the Kenya eClaims FHIR implementation guide, and no full SHA Claim **Bundle** (Organization + Patient + Coverage + Claim) is assembled for submission.
- PHC / PHF zero-total rule not enforced in data** — AegisCare stamps a PHF no-copay note, but a live AfyaLink rule requires PHC claims to have a **zero total amount** and requires servicedPeriod on claim items. This is a real submit-time rejection risk.
- ODPC / DHA administrative readiness** — ODPC registration, DPIA submission, DHA certification application and facility onboarding are not complete.
- Security hardening** — MFA, penetration testing, and some access-control baselines are not yet demonstrated.

Overall readiness:  **PARTIAL** — not ready for DHA certification submission or live SHA claims until the gaps below are closed.

Legal & Regulatory Framework

Requirement: Digital Health Act, 2023 (No. 15 of 2023)

Source: <https://www.health.go.ke/sites/default/files/Digital%20Health%20Bill%20Final.pdf>

Status:  PARTIAL

Implementation: AegisCare implements a digital health record with structured clinical data, audit trails, role-based access control, consent records, and FHIR R4 output intended for DHA HIE.

Gap: No DHA certificate of compliance (valid 2 years per the Health Information Management Procedures Regulations), no ODPC-certified controller/processor evidence submitted, no DHA registration of health data controller notification.

Remediation: Complete DHA certification application; register with ODPC; notify DHA of the controller/processor registration; retain and submit evidence of the DPIA and policies.

Requirement: Digital Health (Data Exchange Component) Regulations, 2025 (Legal Notice 77)

Source: <https://new.kenyalaw.org/akn/ke/act/ln/2025/77/eng@2025-04-11>

Status:  GAP

Implementation: Codebase has FHIR edge functions and a dha_outbound_queue intended for ESB traffic; app_settings includes facility identifiers and KMHFL code; KMHFL auto-sync builds facility registry data.

Gap: Not onboarded onto the Enterprise Service Bus (ESB); no application for onboarding with proof of ODPC registration, DPIA, certification, and onboarding fee; no certificate of compliance.

Remediation: Submit onboarding application to the Agency (regulation 6); provide DPIA, ODPC certificate, developer/facility particulars, and certificate of compliance; pay applicable fee; obtain ESB user licence.

Requirement: Digital Health (Health Information Management Procedures) Regulations, 2025 (Legal Notice 76)

Source: <https://new.kenyalaw.org/akn/ke/act/ln/2025/76/eng@2025-04-11>

Status:  PARTIAL

Implementation: Audit triggers on `sha_claims` , `sha_claim_items` , `sha_claim_status_history` and many other tables; audit log UI; consent OTP flow.

Gap: Audit-log retention policy for the required 20 years is not yet implemented as a documented, enforceable process; no migration of data to national/county health data banks; no archival/death workflow.

Remediation: Define and document 20-year audit retention; implement secure archival; prepare national/county health data bank transfer mapping; document legacy data migration plan.

Requirement: Kenya Health Information Systems Interoperability Framework (KHISIF)

Source:

https://www.data4sdgs.org/sites/default/files/services_files/Kenya%20Health%20Information%20Systems%20Interoperability%20Framework.pdf

Status:  PARTIAL

Implementation: AegisCare uses ICD-11/LOINC/site-specific codes, FHIR R4, standard identifier systems, and interoperable JSON payloads. Existing MOH 204/505/642/705/706/707/717 reports follow MOH tagging architecture.

Gap: Not demonstrated against the KHISIF common service layer / HIS certification framework; health facility data exchange with KHIS/KHISIF is not implemented.

Remediation: Perform KHISIF compliance mapping; document interoperability diagrams; integrate with the national HIS certification pathway.

DHA AfyaLink HIE Compliance

Requirement: FHIR R4 conformance (Bundle, Encounter, Patient, Condition, Claim, Coverage, Organization)

Source: <https://afyalink.dha.go.ke/apidocs/claim-bundle> , <https://igecclaims.intellisoftkenya.com/>

Status:  PARTIAL

Implementation:

- `generate_fhir_encounter(p_encounter_id UUID)` produces FHIR R4 Encounter with ICD-11 diagnoses.
- Edge functions `fhir-patient` , `fhir-encounter` , `fhir-condition` produce FHIR R4 resources.
- `generate_fhir_condition()` and `generate_fhir_encounter()` are used by `dha_outbound_queue` .
- `build_fhir_claim()` emits a FHIR R4 Claim with corrected `sha_claim_items` columns (`intervention_code` , `description` , `amount`), `is_included = true` filter, and `preauth_id` reference.
- `auto_build_fhir_claim()` trigger writes `fhir_bundle` on `sha_claims` insert.

Gap:

- No validated DHA/Kenya eClaims profile conformance report (FHIR validator output).
- No submission Bundle (`type=message`) that includes Organization + Patient + Coverage + Claim with matching `fullUrl` and identifier s.
- `servedPeriod` (start/end date per item), `billablePeriod` , and `CareTeam` / `Practitioner` references are not built into `build_fhir_claim()` .
- Claim items do not yet use the SHA intervention code value-set consistently with OCL/SHA/PFMS.
- `meta.profile` points to generic `http://hl7.org/fhir/StructureDefinition/Claim` rather than a Kenya eClaims / SHA profile.

Remediation:

1. Validate all FHIR output against the Kenya eClaims IG and DHA profiles.
2. Extend `build_fhir_claim()` to include `servedPeriod` , `billablePeriod` , `CareTeam` , `fullUrl` /Bundle entry structure, and DHA profile meta.
3. Build a submission Bundle RPC/edge function that wraps `fhir_bundle` into a `message` Bundle.
4. Add a tests/QA script validating generated bundles with the HL7 FHIR validator.

Requirement: DHA HIE authentication (JWT/OAuth2 client credentials)

Source: <https://afyalink.dha.go.ke/claim-integration> , <https://afyalink.dha.go.ke/sha-portal-api-integration>

Status:  GAP

Implementation: `claims-dispatcher` edge function exists and is designed to send queued items, but it is not live because no credential configuration exists.

Gap: Access/secret keys, OAuth2 client credentials, callback URL configuration, and IP allow-listing have not been provisioned.

Remediation: Obtain credentials from <https://developer.dha.go.ke> / AfyaLink onboarding; configure secrets; register callback URL; test in sandbox/UAT.

Requirement: Client Registry (CR ID) and member identity resolution

Source: <https://hie-docs.dha.go.ke/registries/client-registry> (per existing DOC-7)

Status:  PARTIAL

Implementation: `patients.cr_number` , `patients.national_id` / `national_id_type` , `sha_member_number` , `sha_claims.cr_number_at_claim` , `sha_claims.sha_member_no_at_claim` , and `cr_number_missing` / `sha_member_missing` flags are implemented and surfaced in the SHA claims state machine as "Missing data" badges.

Gap: No live CR lookup (credentials; API not connected). Some existing claims may have been created before CR resolution.

Remediation: Once DHA credentials are available, implement CR lookup at registration/encounter sign and resolve missing flags.

Requirement: ICD-11 diagnostic coding on claims

Source: <https://afyalink.dha.go.ke/claim-integration>

Status:  COMPLIANT (locally)

Implementation: `encounter_diagnoses` table plus `trg_sync_encounter_diagnoses` and ICD-11 format/API (`icd11-search` edge function, MOH ICD-11 mapping for 705).

Gap: Need to confirm every SHA claim's linked encounter carries at least one structured ICD-11 diagnosis; no live terminology service pre-population for all codes.

Remediation: Add a claim submission guard requiring ICD-11 diagnosis on included claim items; optionally integrate with DHA terminology/OCL in production.

SHA Claims Compliance

Requirement: SHA claim lifecycle (draft → submitted → approved/rejected → resubmission → payment)

Source: Kenya SHA / AfyaLink claims guide; DHA SHA Claim Bundle API docs

Status:  COMPLIANT (local workflow) /  PARTIAL (live submission)

Implementation:

- `sha_claims` , `sha_claim_items` , `sha_benefit_packages` , `sha_tariffs` , `sha_claim_packages` .
- `auto_generate_sha_claim()` creates draft claims on encounter sign.
- `auto_build_fhir_claim()` builds FHIR Claim into `fhir_bundle` .
- `sha_claim_status_history` records all admin transitions.
- `resubmission_count` , `payment_reference` , `payment_date` , `last_status_check` on `sha_claims` .
- UI state machine in `src/routes/admin.queue.tsx` (SHA Claims tab): Submit, Approve, Reject, Record Payment, Resubmit, with `status/age/missing-data/PHF` badges.

Gap: Live submission and claim-status polling are not connected (credentials). Aging UI uses the `sha_claims_aging` view but production callback handling for `ClaimResponse` states is not built.

Remediation: Connect `claims-dispatcher` to the live AfyaLink claim endpoint; implement callback ingestion for `queued/approved/rejected/in-review/clinical-review/payment-completed` ; reconcile the SHA state machine with DHA `ClaimResponse` states.

Requirement: SHIF / PHF / ECCIF fund mapping and PHC zero total amount

Source: <https://afyalink.dha.go.ke/claim-integration> ("Any PHC claim must have zero total amount")

Status:  GAP

Implementation: `sha_claims.fund_type` (PHF / SHIF / ECCIF), `sha_fund_type` on encounters, benefit packages by fund, `set_sha_fund_type()` defaults, and `enforce_phf_zero_claim()` banners PHF claims with "PHF: zero patient copay — SHA covers 100%".

Gap: The PHF trigger does **not** enforce the AfyaLink submission rule that PHC claims must have a zero total amount and zero item net amounts. Current `total_amount` may carry a non-zero insurance-covered amount and item `amount` values may be non-zero.

Remediation: Before submission, for PHF/PHC-eligible claims set included item `net / amount` and claim `total_amount` to 0 (or reject non-PHC PHF claims), and add a submitting guard with a clear error message. Re-run the adjusted trigger and validate against the AfyaLink rules.

Requirement: Pre-authorization (preauth) workflow and 72-hour SLA

Source: AfyaLink Preasync / SHA Portal Preauth integration guide

Status:  PARTIAL

Implementation: `preauth_number` , `preauth_id` , `preauth_status` , `preauth_requested_at` , `preauth_approved_at` , `preauth_submitted_at` , `preauth_notes` ; local preauth keywords; preauth missing warning; 72hr SLA timer in the insurance dialog; Eligibility placeholder.

Gap: No live preauth API call or callback handling; no automatic submission of preauth bundles; no persisted `preauth_submitted_at` update from API until credentials are configured.

Remediation: Once SHA/DHA credentials are available, implement the preauth endpoint and `servedPeriod /claim-required services` mapping.

Requirement: Claim items use valid SHA/PFMS intervention codes

Source: <https://afyalink.dha.go.ke/claim-integration> , eClaims IG downloads

Status:  PARTIAL

Implementation: `sha_claim_items.intervention_code` , `invoices/line items` , `sha_tariffs` (seeded Legal Notice 146/147 tariff codes), and `build_fhir_claim()` uses `intervention_code` falling back to `item_type` .

Gap: No validation gate ensuring `intervention_code` is present and in the SHA intervention value set for every included item; SHA/PFMS coverage extension for eligible members not implemented.

Remediation: Add submission-time validation of `intervention_code` against the SHA value-set; populate the coverage extension for PFMS-eligible claims.

Requirement: Claims aging and payment reconciliation

Source: AfyaLink ClaimResponse states (`payment-completed` , `payment-declined` , `sent-for-payment-processing`)

Status:  PARTIAL

Implementation: `sha_claims_aging` view with `age_days` , `aging_status` (`overdue_submission`, `overdue_response`, `needs_resubmission`); state machine UI shows overdue / resubmitted / missing-data badges; `payment_reference` , `payment_date` , `payment_completed` status.

Gap: No DHA payment-notice ingestion; no automatic reconciliation of `payment_reference` / `payment_date` from SHA ClaimResponse to the local record.

Remediation: Implement callback ingestion to populate `payment_reference` / `payment_date` and reconcile approved/paid/payment-completed states.

ODPC Data Privacy Compliance

Requirement: ODPC registration as data controller/processor

Source: <https://www.clydeco.com/en/insights/2026/03/health-data-protection-in-kenya-strategic-compliance>

Status:  GAP

Implementation: Privacy policy, consent dialog, DSAR export, audit logs, break-glass access logging, and role-based access controls exist in the product.

Gap: No ODPC registration certificate, no DPO appointment on record, no DHA notification of controller registration (within 7 days), no published privacy notice for the live deployment.

Remediation: Register with ODPC; appoint/certify DPO; publish Privacy Notice; notify DHA.

Requirement: Data Protection Impact Assessment (DPIA)

Source: DHA Certification framework; Digital Health (Data Exchange) Regulations

Status:  PARTIAL

Implementation: `docs/certification/DOC-2-dpia.md` exists as a draft DPIA.

Gap: DPIA not yet validated/assessed by a qualified assessor; not submitted with DHA certification application.

Remediation: Finalize DPIA, obtain assessor validation, submit as part of DHA certification.

Requirement: Data subject access / DSAR and export

Source: Kenya Data Protection Act, 2019; DHA Health Data Rules

Status:  COMPLIANT (feature) /  PARTIAL (governance)

Implementation: "Export Patient Data (DSAR)" button on patient record (admin-only) exports patient, encounters, admissions, clinical notes, lab orders, radiology orders, prescriptions, invoices, and consents as JSON, and logs `DSAR_EXPORT` to `audit_log` .

Gap: No automated deletion/rectification workflow; no retention notices wired into an enforceable policy; DSAR acknowledgement SLA (30 days) not tracked as a task.

Remediation: Add DSAR request tracking and deletion/erasure procedure; set 30-day SLA alerts.

Requirement: Consent and sensitive personal data safeguards

Source: Data Protection Act 2019; DHA SHR consent requirements

Status:  PARTIAL

Implementation: OTP consent flow for SHA claim consent, consent records in `consent_otps` / `patient_consents` , `ConSentDialog` , explicit preauth/consent requirements.

Gap: Not all processing activities have documented lawful-basis assessments; biometric identity verification is not implemented; consent-token SHR flow not connected to live DHA.

Remediation: Perform lawful-basis assessment for each processing activity; document biometric identity gap in DPIA; implement SHR consent APIs once credentials are available.

Requirement: Breach notification (ODPC 72 hours / DHA 48 hours)

Source: <https://www.clydeco.com/en/insights/2026/03/health-data-protection-in-kenya-strategic-compliance>

Status:  GAP

Implementation: No automated incident/breach notification workflow exists.

Gap: No documented breach response plan or notification timers to ODPC and DHA.

Remediation: Implement incident-response runbook with 72-hour ODPC and 48-hour DHA notification workflows and test it.

Requirement: 20-year health data retention

Source: Digital Health (Health Information Management Procedures) Regulations, 2025; Digital Health Act 2023 s.31

Status: ⚠ PARTIAL

Implementation: Audit logs are retained in DB; existing certification docs include backup/recovery policy.

Gap: No enforceable data-retention matrix for 20-year health data; no archival workflow.

Remediation: Publish retention matrix, enable archival, retain audit logs 20 years, update backup/recovery policy with tested RPO/RTO.

Infrastructure & Hosting Compliance

Requirement: Secure, auditable infrastructure and access

Status: ⚠ PARTIAL

Implementation: Supabase RLS, role-based permissions, break-glass logging, audit triggers, server-side Supabase auth.

Gap:

- MFA not implemented.
- Penetration test not performed.
- Server-side password policy / account lockout not demonstrated.
- Secrets configuration not verifiable outside the build env.
- Free-tier Supabase cron/automation pauses can interrupt dispatch or compliance jobs.
- Facility/country-level data residency for Kenya health data not confirmed (hosted outside Kenya).

Remediation: Enable MFA; run penetration test; document password/lockout policy; move to a paid Supabase plan; confirm/harden data residency and cross-border transfer safeguards (SCCs/TIA); perform backups and restores with tested RTO/RPO.

Requirement: Audit trail completeness and tamper protection

Source: Digital Health (Health Information Management Procedures) Regs, 2025 (audit logs retained 20 years)

Status: ⚠ PARTIAL

Implementation: `audit_trigger_fn()` attached to many tables, including `sha_claims` , `sha_claim_items` , `sha_claim_status_history` ; admin audit-log view.

Gap: Audit log immutability/append-only and 20-year retention not fully demonstrated.

Remediation: Enforce append-only/immutable storage for `audit_log`; implement off-site archival with 20-year retention.

Gap Analysis Summary Table

#	Area	Status
1	DHA certification application / certificate	🔴 GAP
2	DHA ESB onboarding	🔴 GAP
3	DHA/AfyaLink credentials (OAuth/JWT/access keys)	🔴 GAP
4	Kenya eClaims FHIR profile conformance	⚠ PARTIAL
5	Full SHA Claim message Bundle assembly	🔴 GAP
6	<code>servedPeriod</code> / <code>billablePeriod</code> / <code>CareTeam</code> on Claim	🔴 GAP
7	PHC/PHF zero total amount	🔴 GAP
8	SHA intervention code validation	⚠ PARTIAL
9	Local SHA claims state machine	✅ COMPLIANT
10	<code>build_fhir_claim()</code> column fix	✅ COMPLIANT
11	<code>sha_claim_status_history</code>	✅ COMPLIANT
12	<code>resubmission_count</code> / <code>payment</code> columns	✅ COMPLIANT
13	<code>sha_claims_aging</code> view	✅ COMPLIANT
14	KMHFL facility sync	✅ COMPLIANT
15	DSAR export	✅ COMPLIANT (feature) / ⚠ PARTIAL (governance)

16	Preauth 72hr SLA timer	✅ COMPLIANT (UI) / ⚠️ PARTIAL (live)
17	SHA Eligibility check	🔴 GAP (pending credentials)
18	ODPC registration / DPO	🔴 GAP
19	DPIA submission	⚠️ PARTIAL
20	Breach notification workflow	🔴 GAP
21	MFA	🔴 GAP
22	Penetration test	🔴 GAP
23	20-year retention/archival	⚠️ PARTIAL
24	Kenya data hosting / cross-border controls	⚠️ PARTIAL
25	Biometric verification	🔴 GAP
26	Supabase free-tier cron availability	⚠️ PARTIAL
27	Audit log immutability	⚠️ PARTIAL
28	KHIS / MoH reporting integration	⚠️ PARTIAL
29	Live ClaimResponse / payment reconciliation	🔴 GAP

Compliance Roadmap

Phase 1 — Now (no external dependency)

- Enforce PHC/PHF zero total amount and `servedPeriod` in `build_fhir_claim()` /submission guard.
- Add a submission Bundle builder and FHIR validator QA script.
- Publish ODPC privacy notice, data-protection policy, 20-year retention matrix, breach runbook, DSAR 30-day SLA process.
- Enable MFA; run penetration test; harden password/lockout.
- Track and close the identified security gaps.

Phase 2 — Credentials & sandbox (blocked on DHA/SHA onboarding)

- Register with ODPC, obtain certificate, appoint DPO, notify DHA.
- Obtain AfyaLink test credentials; configure secrets and callback URL.
- Complete FHIR IG conformance validation; submit DHA certification application (Form HMIS 4).
- Implement live Client Registry lookup, SHA eligibility check, preauth submit, claim submit.
- Implement ClaimResponse callback ingestion and payment reconciliation.

Phase 3 — Production readiness

- DHA certificate of compliance (2-year validity).
- ESB onboarding and user licence.
- National/county health data bank transfer plan + 20-year archival.
- Biometric identity verification (if in scope for deployment).
- Move to paid Supabase tier, confirm data residency, implement cross-border transfer controls.
- Complete KHIS and MOH reporting interoperability mapping.
- Annual re-certification and ongoing ODPC conformity.